LAB 8: THE COMPLETE CLUSTER BOMB ATTACK

PART 1: WHAT IS BURP SUITE AND WHY USE IT?

What is Burp Suite?

Burp Suite is a professional tool for testing web application security. At its core, it's an intercepting proxy.

Think of it this way:

- Normally, your Browser talks directly to the Website Server.
- When Burp Suite is running, your Browser talks to Burp Suite interceptor, which then talks to the Website Server.

It's like a post office that sits between you and the website. It allows you to read, modify, and even stop any "mail" (HTTP requests) you send, or any "mail" (HTTP responses) you get back.

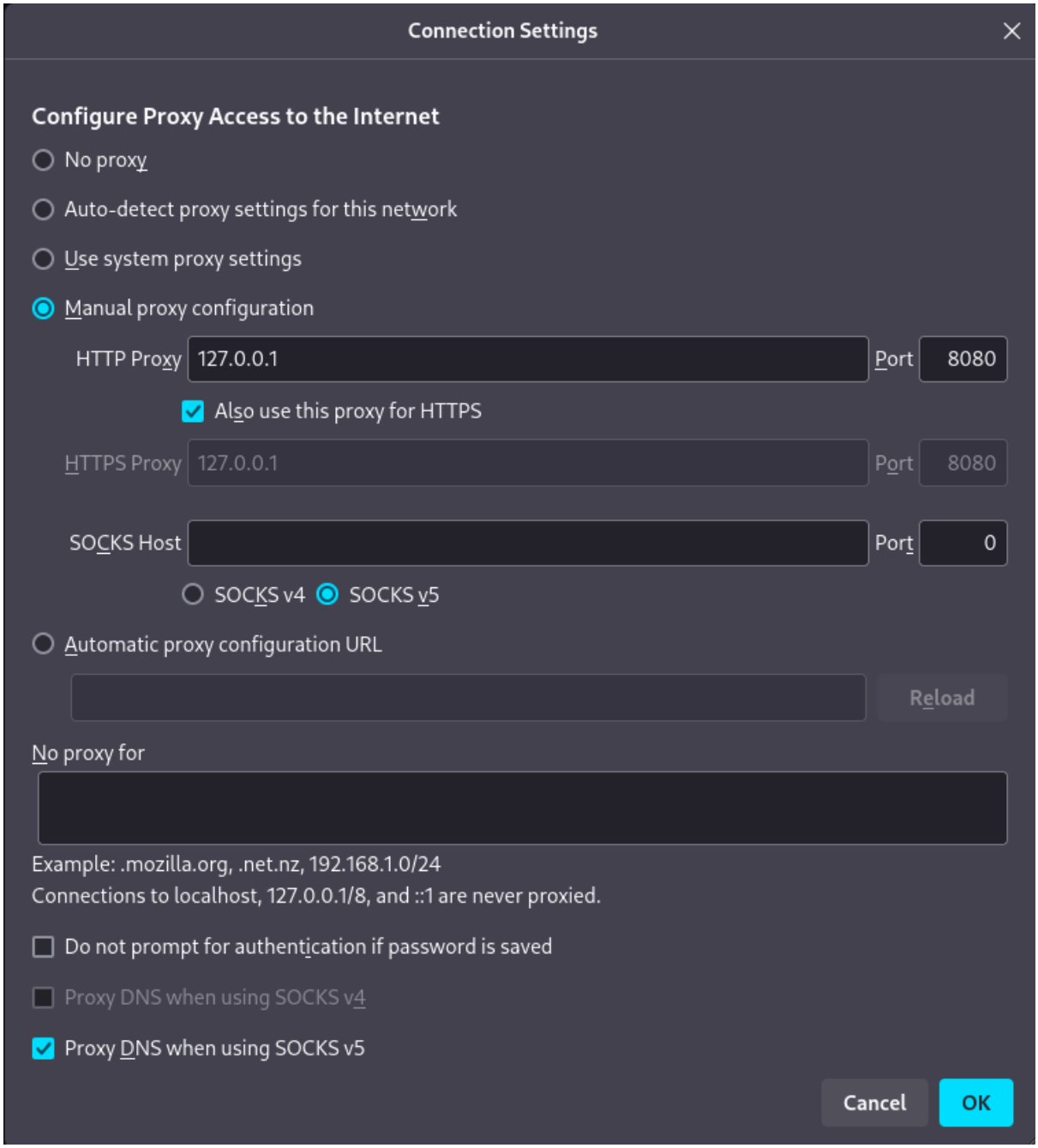
Why are we using it for this lab?

1. To See the "Invisible": Browsers hide all the technical details from you. Burp shows us the raw HTTP requests and responses so we can see what's *really* being sent (like uid=test&passw=test).
2. To Automate Attacks: Manually trying 5 usernames and 5 passwords would mean 25 separate login attempts. This is slow and tedious. Burp's Intruder tool lets us automate this process, sending all 25 combinations in seconds and organizing the results in a perfect table.

PART 2: CONFIGURE BURP PROXY IN FIREFOX

First, we must tell Firefox to send all its traffic to Burp Suite.

1. Open Burp Suite: Launch Burp. Go to the Proxy tab, then the Options sub-tab.
2. Check Proxy Listener: Make sure you have a proxy listener running on 127.0.0.1:8080. This is enabled by default.
3. Open Firefox: Open the Firefox browser in your Kali VM.
4. Go to Network Settings:
    a. Click the menu icon (☰) in the top-right.
    b. Go to Settings.
    c. In the "General" panel, scroll all the way down to Network Settings and click the "Settings..." button.
5. Configure the Proxy:
    a. Select "Manual proxy configuration".
    b. Set HTTP Proxy to 127.0.0.1 and Port to 8080.
    c. Check the box "Also use this proxy for HTTPS".
    d. Crucially: At the bottom, in the "No proxy for" box, *delete* any text that is there (like localhost, 127.0.0.1). This box must be empty.
    e. **Click OK.**



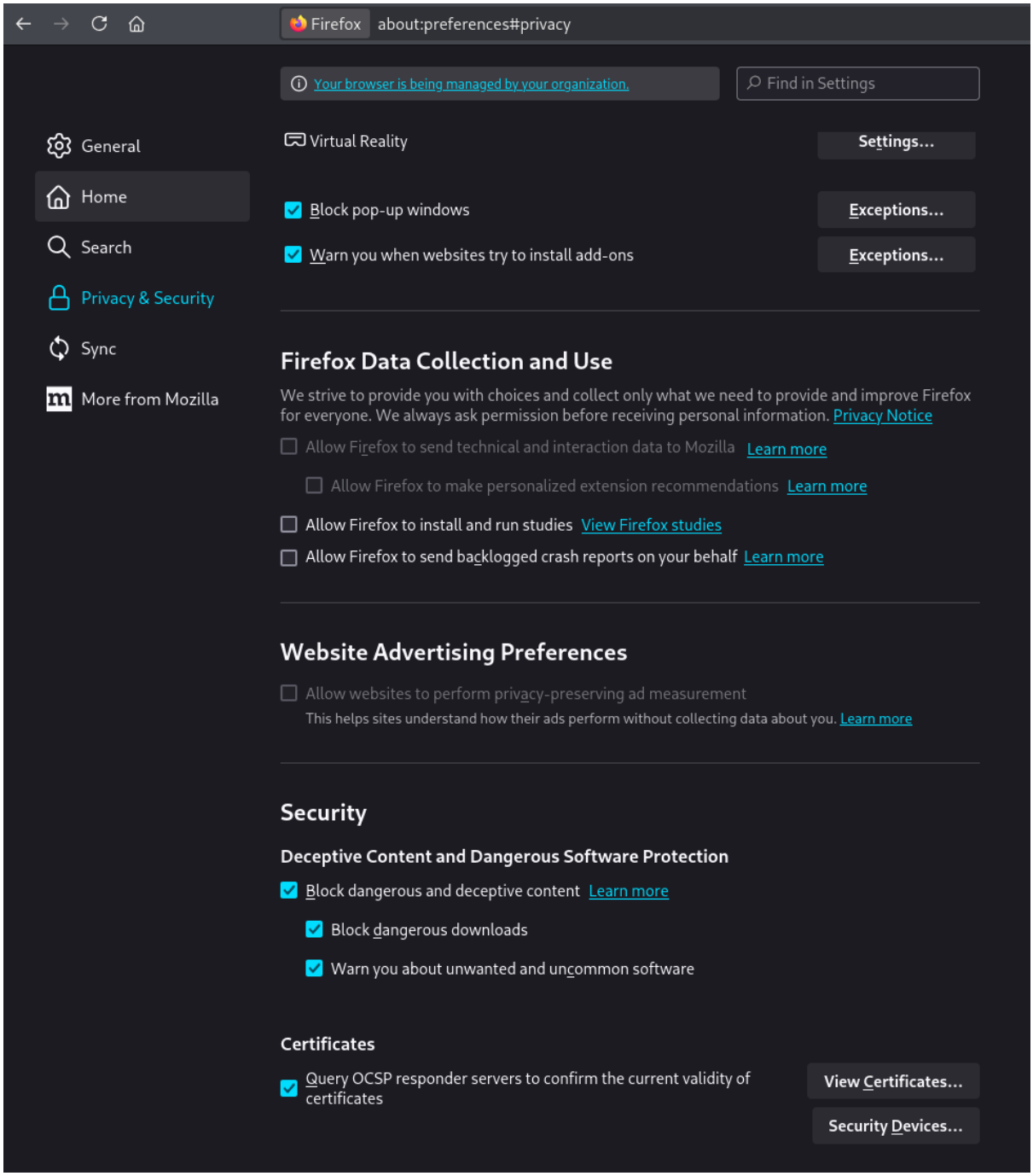
PART 3: INSTALL THE BURP CA CERTIFICATE

To let Burp intercept encrypted HTTPS traffic (not needed for this http lab, but essential for all modern sites), Firefox must trust Burp.

1. Go to the Burp URL: With the proxy still on, type this exact address into the Firefox URL bar:

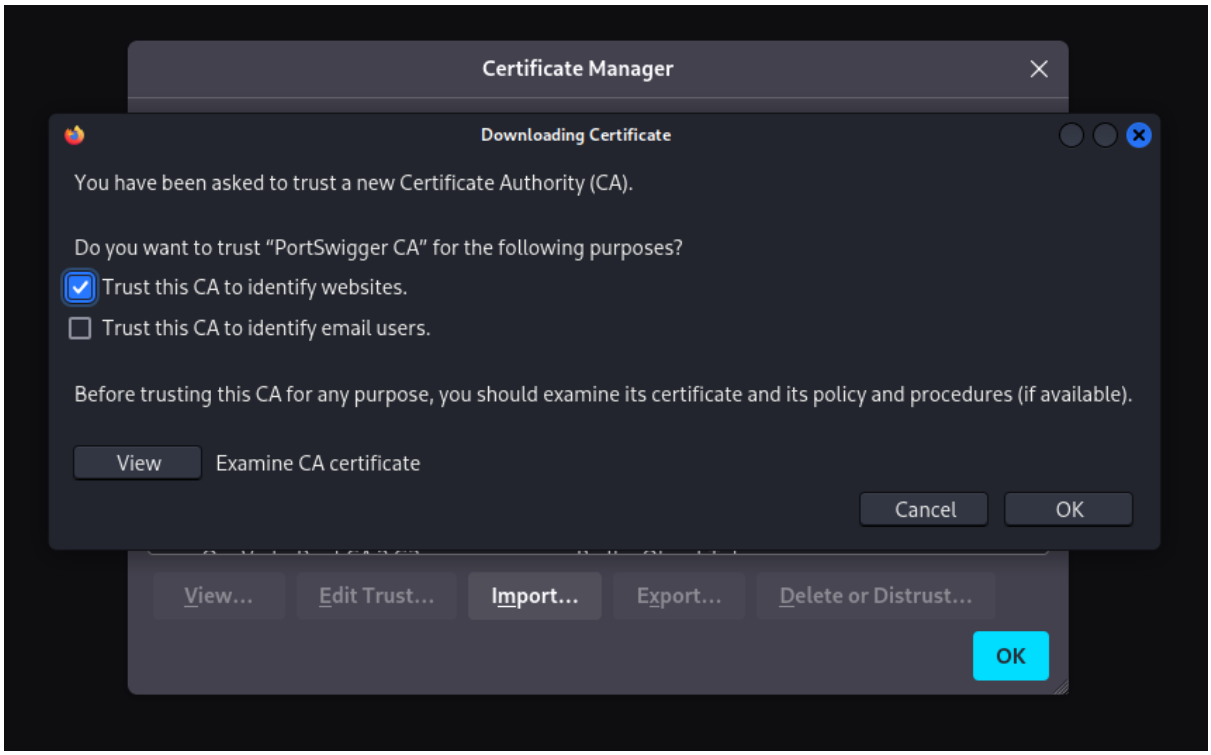
```
Lab 8-Burpsuite URL                    Bash
http://burpsuite
```

2. Download Certificate: You'll see a "Welcome to Burp Suite" page. In the top-right corner, click "CA Certificate" to download the cacert.der file. Save it somewhere you can find it.
3. Import Certificate:
    a. In Firefox, go back to Settings.
    b. Go to Privacy & Security.
    c. Scroll all the way down to the Certificates section and click "View Certificates...".
    d. A new window will open. Click the "Authorities" tab.
    e. Click the "Import..." button.
    f. Find and select the cacert.der file you just downloaded.



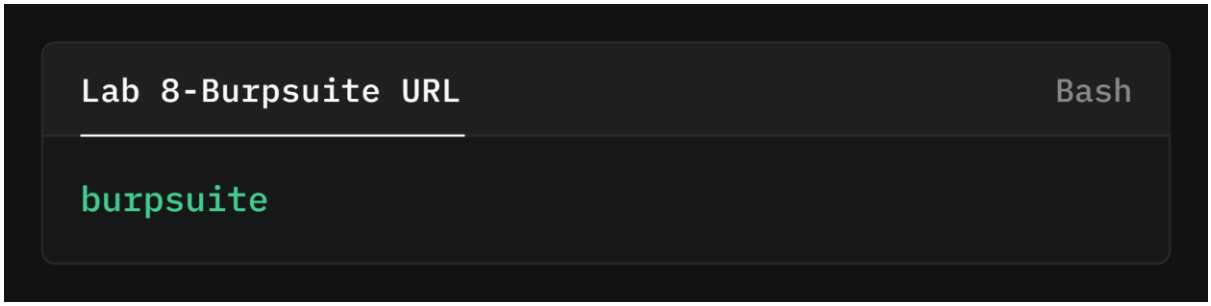
4. Trust the Certificate:
    a. A pop-up will ask what to trust. Check the box for "Trust this CA to identify websites".
    b. Click OK, then OK again to close all windows.

c. Restart Firefox for good measure.

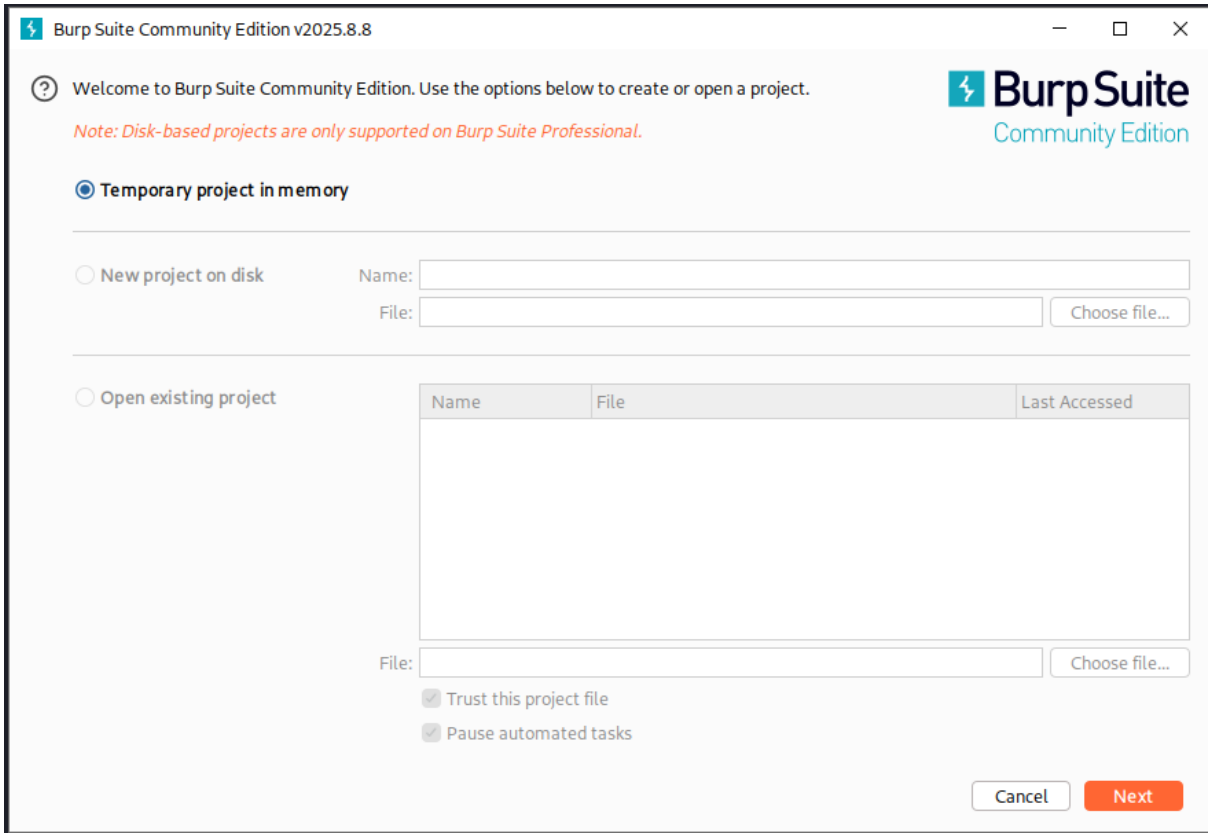


PART 4: VERIFY THE PROXY

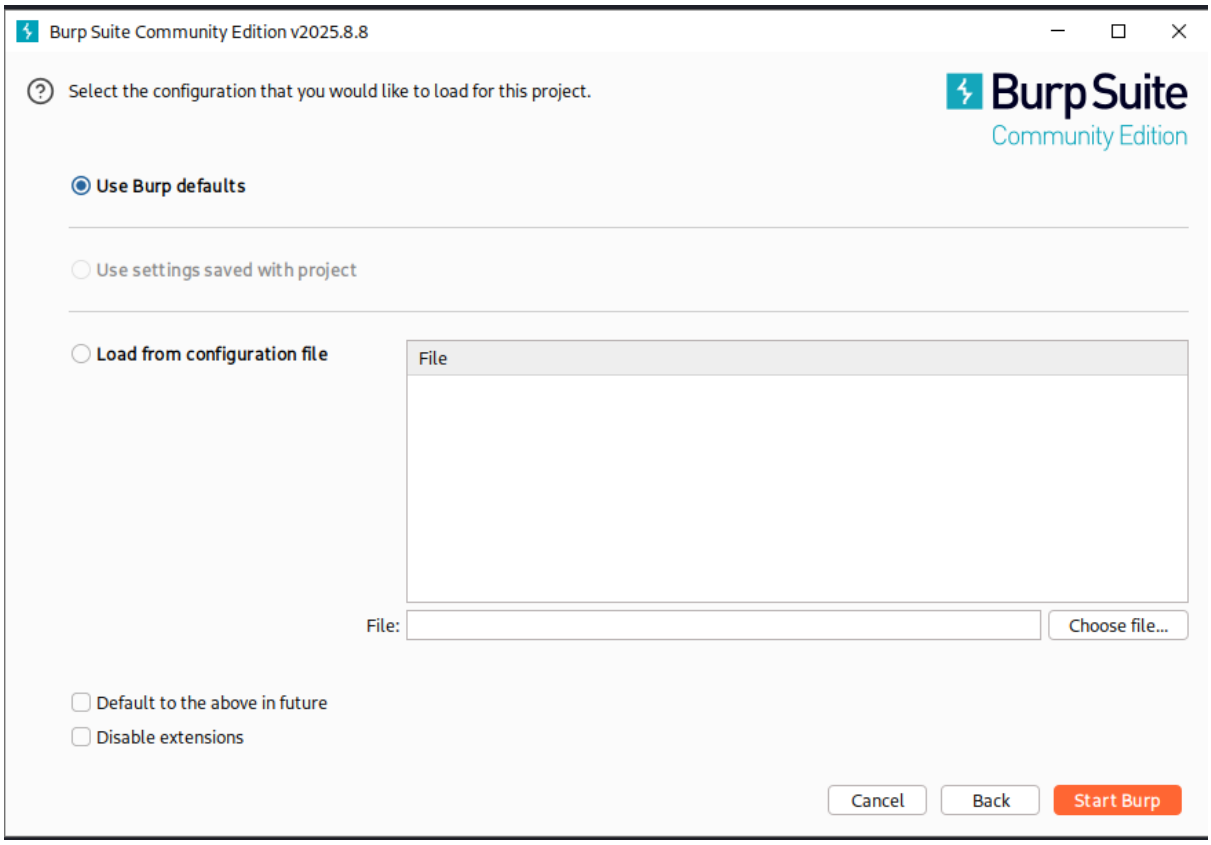
1. To open burp suit, open your terminal and enter the following command:



Follow the steps as shown in the images below:

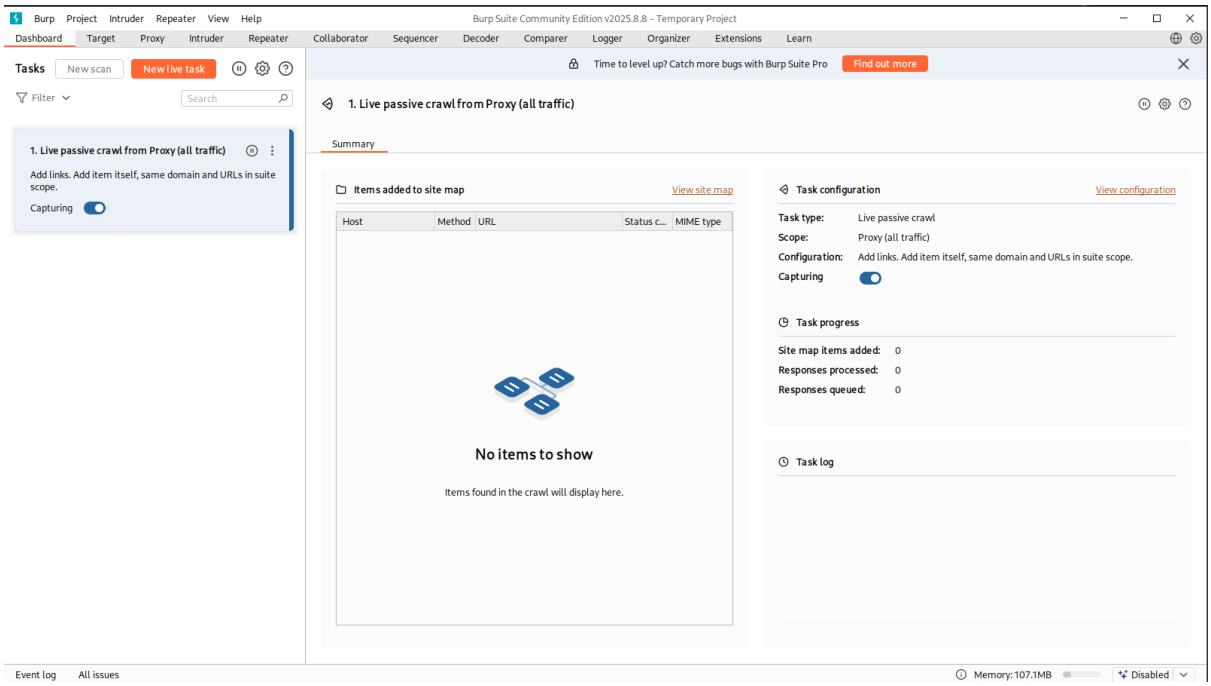


Click Next

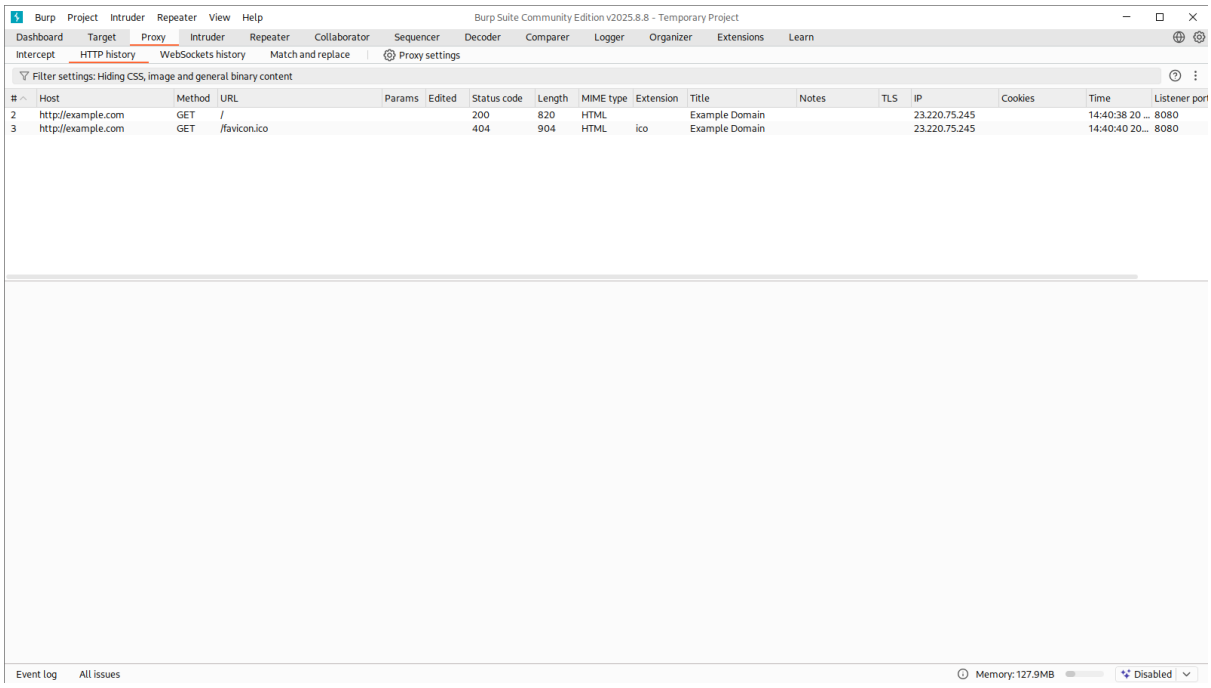


Click Start Burp

You will most likely be shown the following screen:



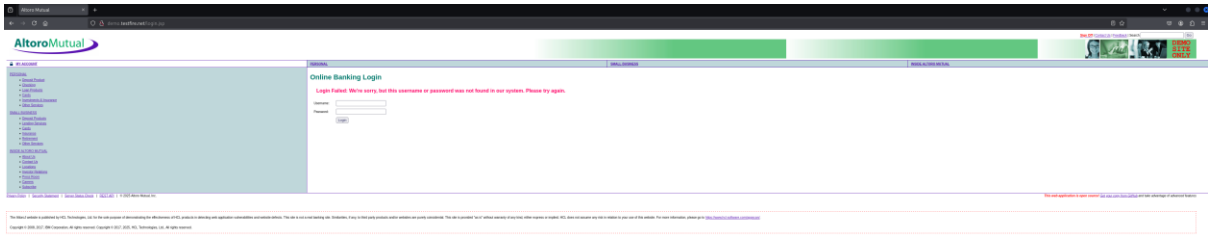
2. In Burp Suite, go to the Proxy tab > HTTP history tab.
3. In Firefox, browse to http://example.com.
4. You should see the traffic show up in Burp's history. This confirms your proxy is working!



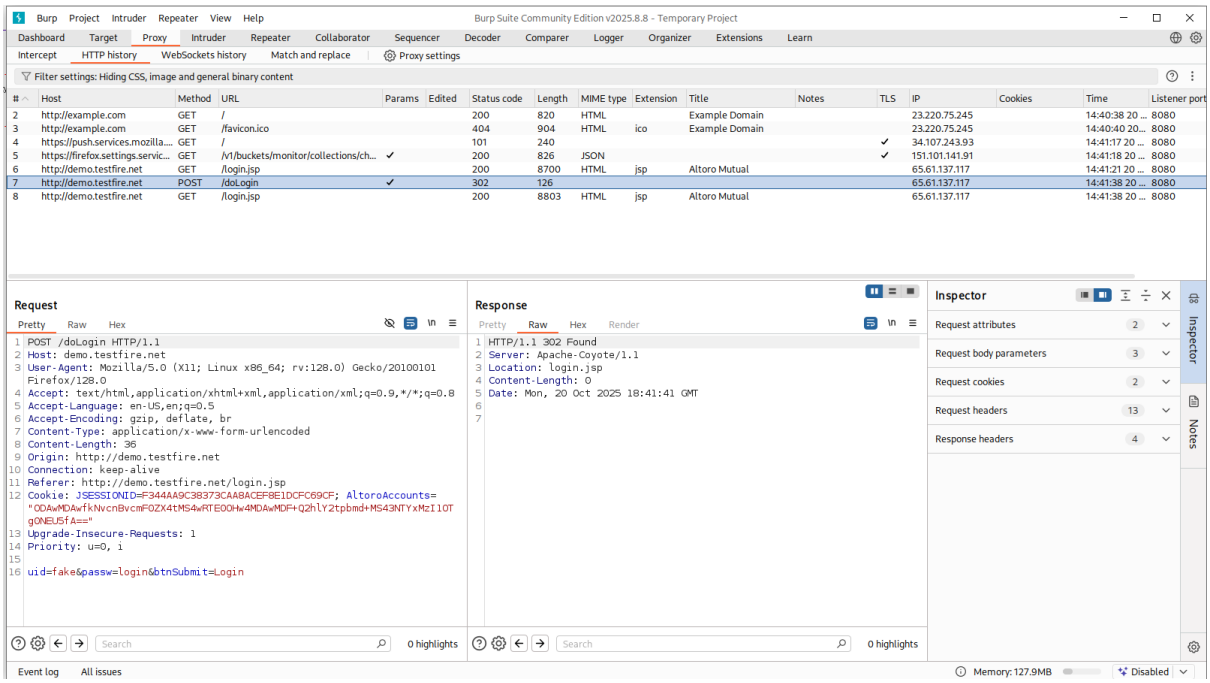
5. For this lab, make sure Intercept is off (in the Proxy > Intercept tab).

PART 5: CAPTURE THE LOGIN REQUEST

1. In Firefox, go to the lab's login page: http://demo.testfire.net/login.jsp
2. On the login form, enter any fake credentials, like test and test, and click "Login".



3. In Burp Suite, go to the Proxy > HTTP history tab. Find the request you just sent: POST /doLogin



4. Right-click on that request and select "Send to Intruder".

Request

Pretty Raw Hex

```
1  POST /doLogin HTTP/1.1
2  Host: demo.testfire.net
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101
   Firefox/128.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Content-Type: application/x-www-form-urlencoded
8  Content-Length: 36
9  Origin: http://demo.testfire.net
10 Connection: keep-alive
11 Referer: http://demo.testfire.net/login.jsp
12 Cookie: JSESSIONID=F344AA9C38373CAA8ACEF8E1DCFC69CF; AltoroAccounts=
   "ODAwMDAwfkNvcnBvcmFOZX4tMS4wRTEOOHw4MDAwMDF+Q2hlY2tpbmd+MS43NTYxMzI1OT
   gONEU5fA=="
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 uid=fake&passw=login&btnSubmit=Login
```

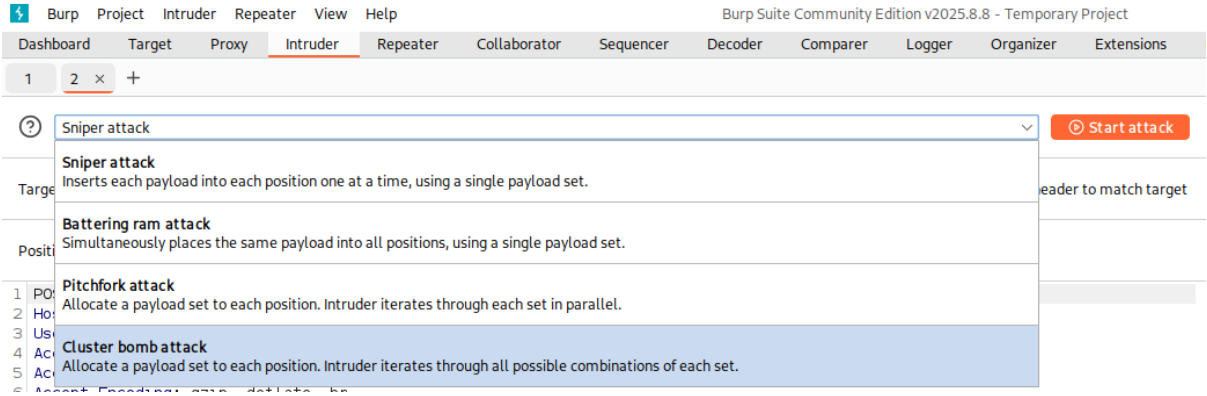
Search 0 highlights

Event log All issues

- Scan
- Send to Intruder Ctrl+I
- Send to Repeater Ctrl+R
- Send to Sequencer
- Send to Comparer
- Send to Decoder
- Send to Organizer Ctrl+O
- Show response in browser
- Record an issue [Pro version only] >
- Request in browser >
- Engagement tools [Pro version only] >
- Copy Ctrl+C
- Copy URL
- Copy as curl command (bash)
- Copy to file
- Save item
- Convert selection >
- Cut Ctrl+X
- Copy Ctrl+C
- Paste Ctrl+V
- Message editor documentation
- Proxy history documentation

PART 6: CONFIGURE THE CLUSTER BOMB ATTACK

1. Click the Intruder tab (it should be highlighted in orange).
2. Select Attack Type: At the top, change the Attack type dropdown from "Sniper" to "Cluster Bomb".



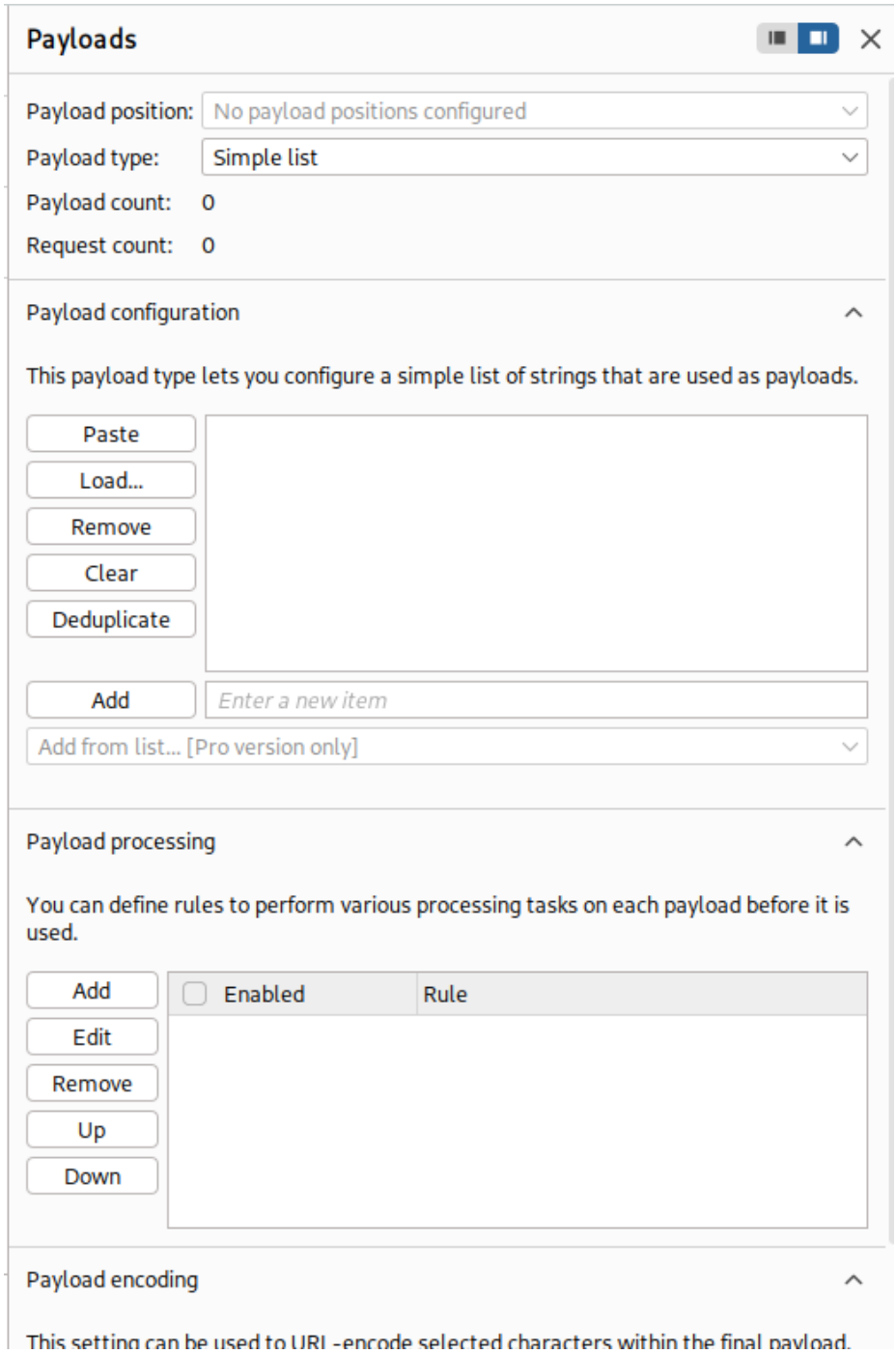
3. Set Positions: Click the "Clear §" button on the right to remove all default markers.
   a. In the request body at the bottom, find your fake login: uid=test&passw=test&btnSubmit=Login
   b. Highlight the username value (the value you entered, in my case I have entered fake) and click "Add §".
   c. Highlight the password value (the value you entered, in my case I have entered login) and click "Add §".
   d. Your request body should now look like this: uid=§fake§&passw=§logint§&btnSubmit=Login

```
POST /doLogin HTTP/1.1
Host: demo.testfire.net
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 36
Origin: http://demo.testfire.net
Connection: keep-alive
Referer: http://demo.testfire.net/login.jsp
Cookie: JSESSIONID=F344AA9C38373CAA8ACEF8E1DCFC69CF; AltoroAccounts=
"ODAwMDAwfkNvcnBvcmF0ZX4tMS4wRTE0OHw4MDAwMDF+Q2hlY2tpbmd+MS43NTYxMzI1OTgONEU5fA=="
Upgrade-Insecure-Requests: 1
Priority: u=0, i

uid=fake&passw=login&btnSubmit=Login
```

PART 7: CONFIGURE PAYLOADS

1. Go to the Payloads sub-tab.

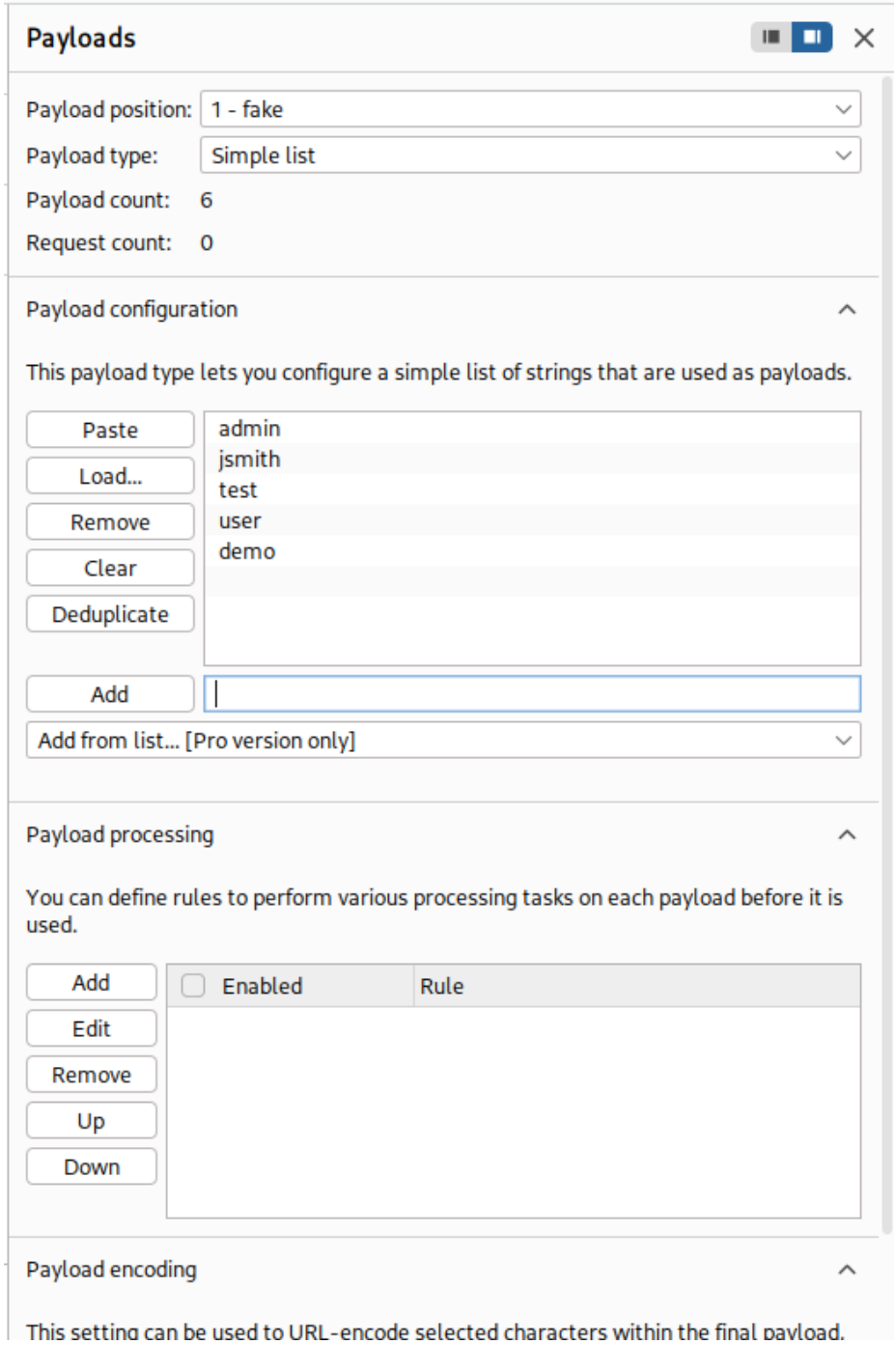


2. You will now see two payload sets to configure.
3. Payload Set 1 (Usernames):

    a. Make sure the Payload set dropdown shows 1.
    b. Under Payload Options, type or paste your list of 5 usernames:

Payload-Lab 8 Bash

```bash
admin
jsmith
test
user
demo
```

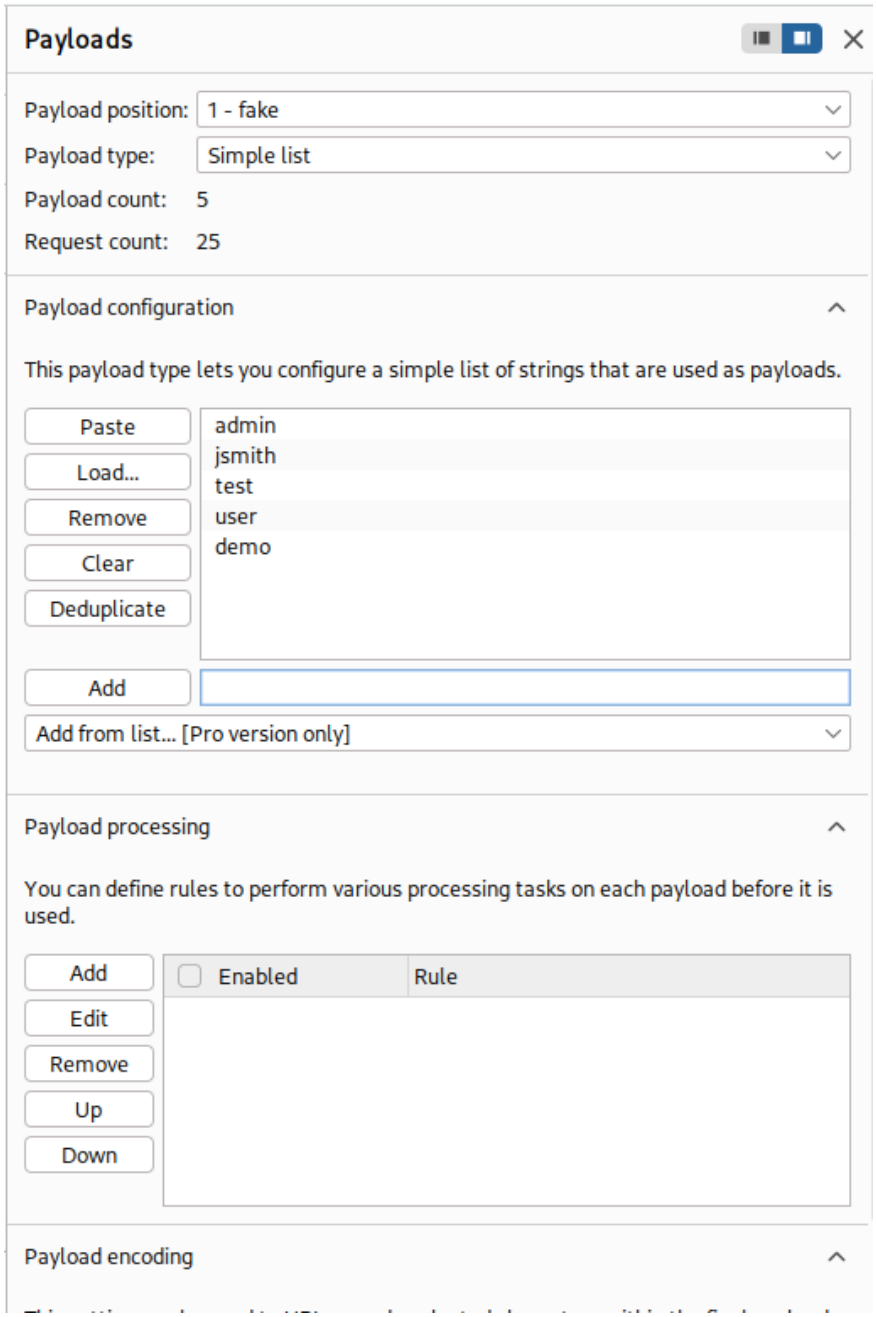


4. Payload Set 2 (Passwords):

a. Change the Payload set dropdown to 2.
b. Under Payload Options, type or paste your list of 5 passwords:

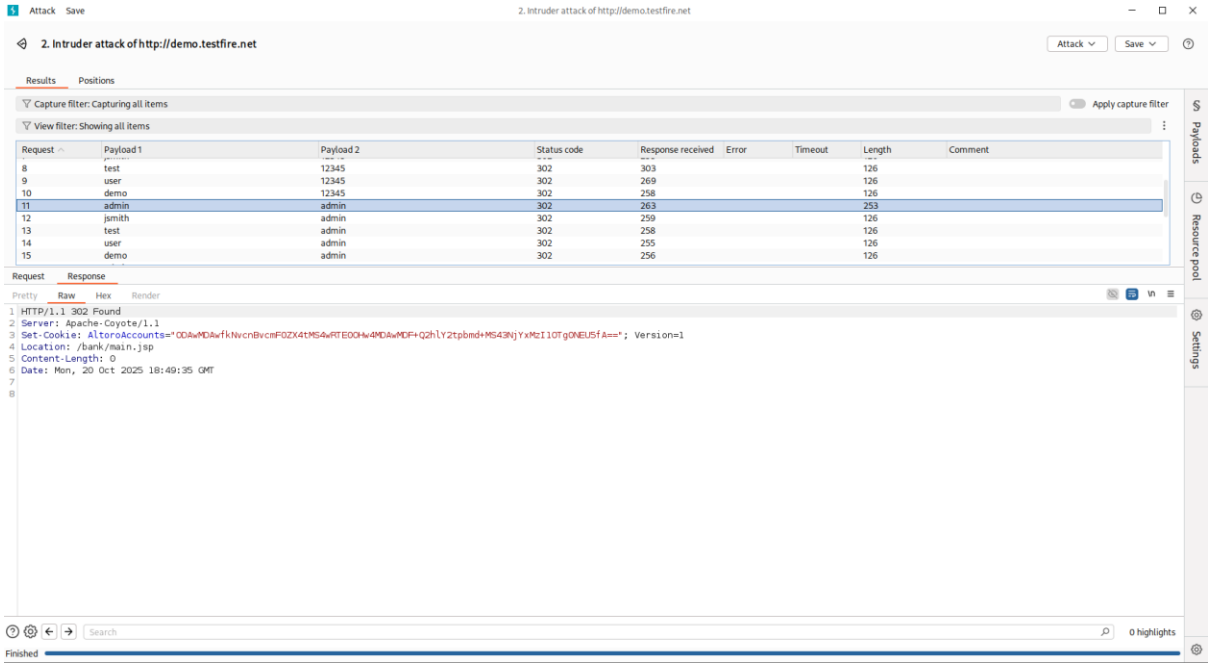
```
password
12345
admin
test
Demo1234
```

c. Check the Request count at the top. It should say 25 (5 usernames × 5 passwords).



PART 8: RUN THE ATTACK AND ANALYZE BY LENGTH

1. Click "Start attack" (in the top-right corner).
2. A new attack window will open and begin running all 25 requests.
3. Analyze the Results:
    a. Look at the columns, specifically Status and Length.
    b. All failed logins will have a 302 Status and the *exact same* Length (e.g., 126 bytes).
    c. The one successful login will also have a 302 Status but a different Length (e.g., 253 bytes).
    d. Click the "Length" column header to sort the results. The unique one will jump right to the top or bottom.



4. Confirm the Winner:
    a. Click on the single row with the *unique* length.
    b. In the bottom panel, click the Response tab.
    c. You will see the successful redirect: Location: /bank/main.jsp.
    d. The other rows will show Location: /login.jsp.
    e. The payloads for the winning row will be admin and admin